

Firewalls

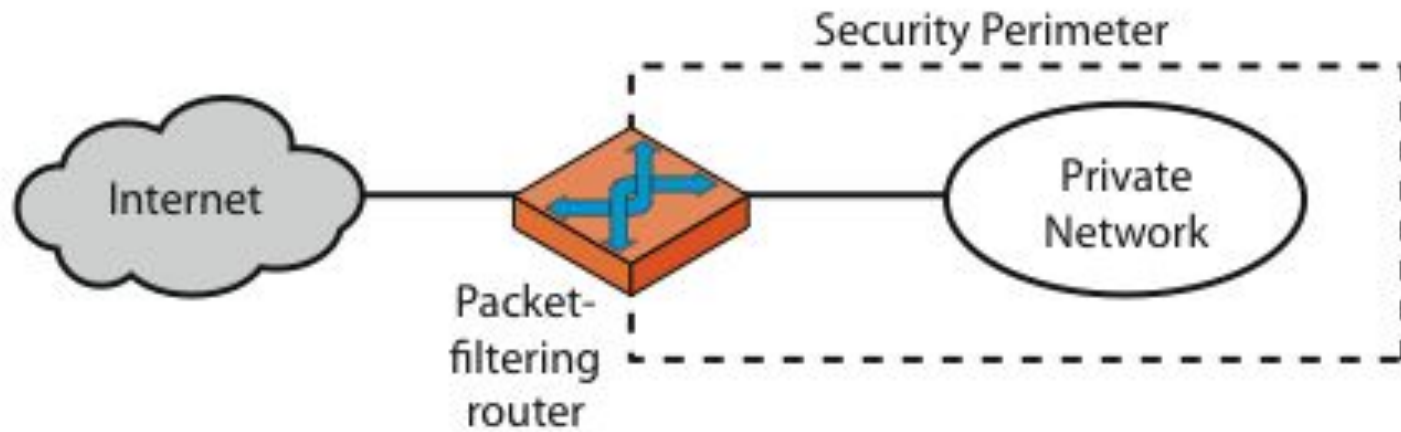
Objectives and Deliverable

- Understand the concept of firewalls and the three major categories: packet filters (stateless vs. stateful) and application level proxy
- Can apply them to detect different attacks
- Be able to write the stateless packet filter rules

What is a Firewall?

- A **choke point** of control and monitoring
- Interconnects networks with differing trust
- Imposes restrictions on network services
 - only authorized traffic is allowed
- Auditing and controlling access
 - can implement alarms for abnormal behavior
- Itself immune to penetration
- Provides **perimeter defence**

Firewalls – Packet Filters



(a) Packet-filtering router

Classification of Firewall

Characterized by protocol level it controls in

- Packet filtering
- Circuit gateways
- Application gateways

Firewalls – Packet Filters

- Simplest of components
- Uses transport-layer information only
 - IP Source Address, Destination Address
 - Protocol/Next Header (TCP, UDP, ICMP, etc)
 - TCP or UDP source & destination ports
 - TCP Flags (SYN, ACK, FIN, RST, PSH, etc)
 - ICMP message type
- Examples
 - DNS uses port 53
 - No incoming port 53 packets except known trusted servers

Usage of Packet Filters

- Filtering with incoming or outgoing interfaces
 - E.g., Egress filtering of spoofed IP addresses
 - Ingress filtering
- Permits or denies certain services
 - Requires intimate knowledge of TCP and UDP port utilization on a number of operating systems

How to Configure a Packet Filter

- Start with a security policy
- Specify allowable packets in terms of logical expressions on packet fields
- Rewrite expressions in syntax supported by your vendor
- General rules - least privilege
 - All that is not expressly permitted is prohibited
 - If you do not need it, eliminate it

Every ruleset is followed by an implicit rule reading like this.

action	src	port	dest	port	comment
block	*	*	*	*	<i>default</i>

Example 1:

Suppose we want to allow inbound mail (SMTP, port 25) but only to our gateway machine. Also suppose that traffic from some particular site SPIGOT is to be blocked.

Solution 1:

action	src	port	dest	port	comment
block	SPIGOT	*	*	*	<i>we don't trust these people</i>
allow	*	*	OUR-GW	25	<i>connection to our SMTP port</i>

Example 2:

(only for advanced students who are interested)

Now suppose that we want to implement the policy “any inside host can send mail to the outside”.

Security & Performance of Packet Filters

- Tiny fragment attacks
 - Split TCP header info over several tiny packets
 - Either discard or reassemble before check
- Degradation depends on number of rules applied at any point
- Order rules so that most common traffic is dealt with first
- Correctness is more important than speed

Rule	Source Address	Destination Address	Action	Comments
R1	111.11/16	222.22.22/24	permit	Let datagrams from Bob's university network into a restricted subnet.
R2	111.11.11/24	222.22/16	deny	Don't let traffic from Trudy's subnet into anywhere within Alice's network.
R3	0.0.0.0/0	0.0.0.0/0	deny	Don't let traffic into Alice's network.

Datagram Number	Source IP Address	Destination IP Address	Desired Action	Action Under R2, R1, R3	Action Under R1, R2, R3
P1	111.11.11.1 (hacker subnet)	222.22.6.6 (corp.net)			
P2	111.11.11.1 (hacker subnet)	222.22.22.2 (special subnet)			
P3	111.11.6.6 (univ. net, not the hacker subnet)	222.22.22.2 (special subnet)			
P4	111.11.6.6 (univ. net, not the hacker subnet)	222.22.6.6 (corp. net)			

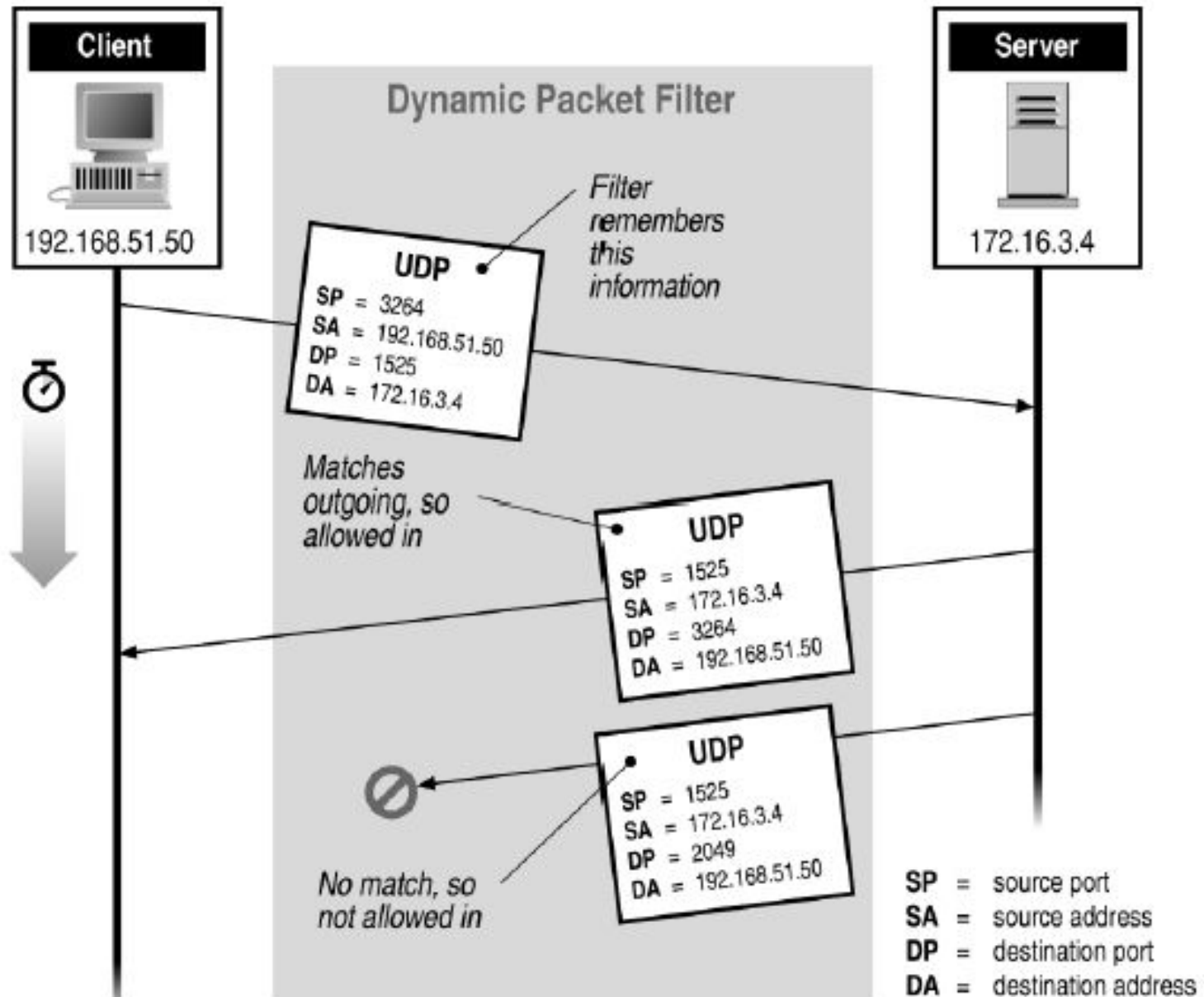
Port Numbering

- TCP connection
 - Server port is number less than 1024
 - Client port is number between 1024 and 16383
- Permanent assignment
 - Ports <1024 assigned permanently
 - 20,21 for FTP 23 for Telnet
 - 25 for server SMTP 80 for HTTP
- Variable use
 - Ports >1024 must be available for client to make any connection
 - This presents a limitation for stateless packet filtering
 - If client wants to use port 2048, firewall must allow *incoming* traffic on this port
 - Better: stateful filtering knows outgoing requests

Firewalls – Stateful Packet Filters

- Traditional packet filters do not examine transport layer context
 - ie matching return packets with outgoing flow
- Stateful packet filters address this need
- They examine each IP packet in context
 - Keep track of client-server sessions
 - Check each packet validly belongs to one
- Hence are better able to detect bogus packets out of context

Stateful Filtering



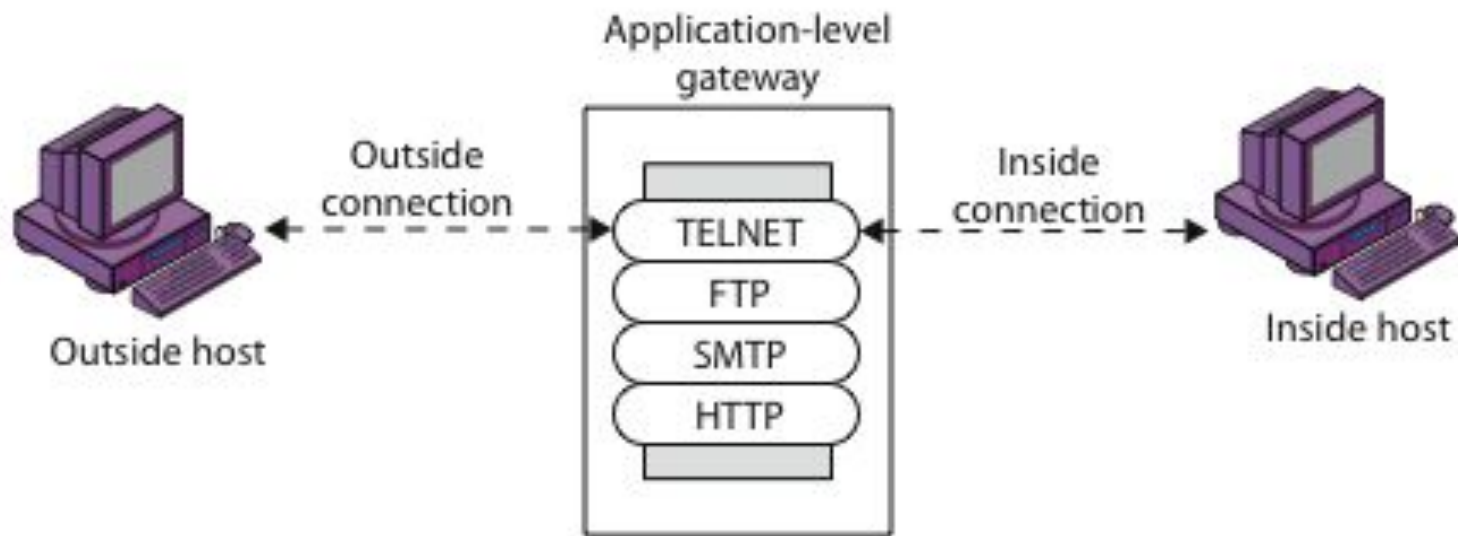
Firewall Outlines

- Packet filtering
- *Application gateways*
- Circuit gateways

Firewall Gateways

- Firewall runs set of proxy programs
 - Proxies filter incoming, outgoing packets
 - All incoming traffic directed to firewall
 - All outgoing traffic appears to come from firewall
- Policy embedded in proxy programs
- Two kinds of proxies
 - Application-level gateways/proxies
 - Tailored to http, ftp, smtp, etc.
 - Circuit-level gateways/proxies
 - Working on TCP level

Firewalls - Application Level Gateway (or Proxy)

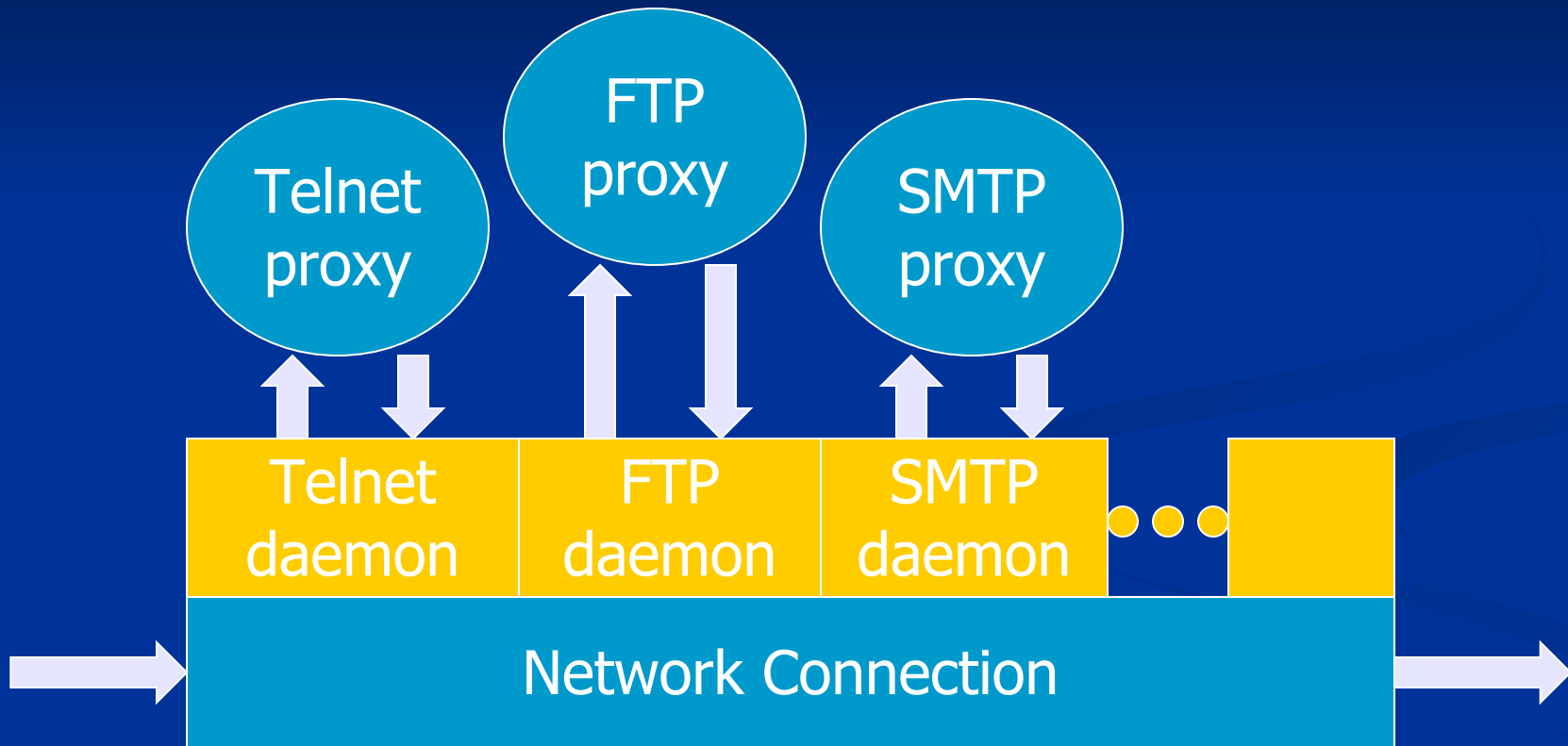


(b) Application-level gateway

Application-Level Filtering

- Has full access to protocol
 - user requests service from proxy
 - proxy validates request as legal
 - then actions request and returns result to user
- Need separate proxies for each service
 - E.g., SMTP (E-Mail)
 - NNTP (Net news)
 - DNS (Domain Name System)
 - NTP (Network Time Protocol)
 - custom services generally not supported

App-level Firewall Architecture



Daemon spawns proxy when communication detected

Enforce policy for specific protocols

- E.g., Virus scanning for SMTP
 - Need to understand MIME, encoding, Zip archives

Firewalls Aren't Perfect?

- Useless against attacks from the inside
 - Evildoer exists on inside
 - Malicious code is executed on an internal machine
- Organizations with greater insider threat
 - Banks and Military
- Cannot protect against transfer of all virus infected programs or files
 - because of huge range of O/S & file types

Quiz

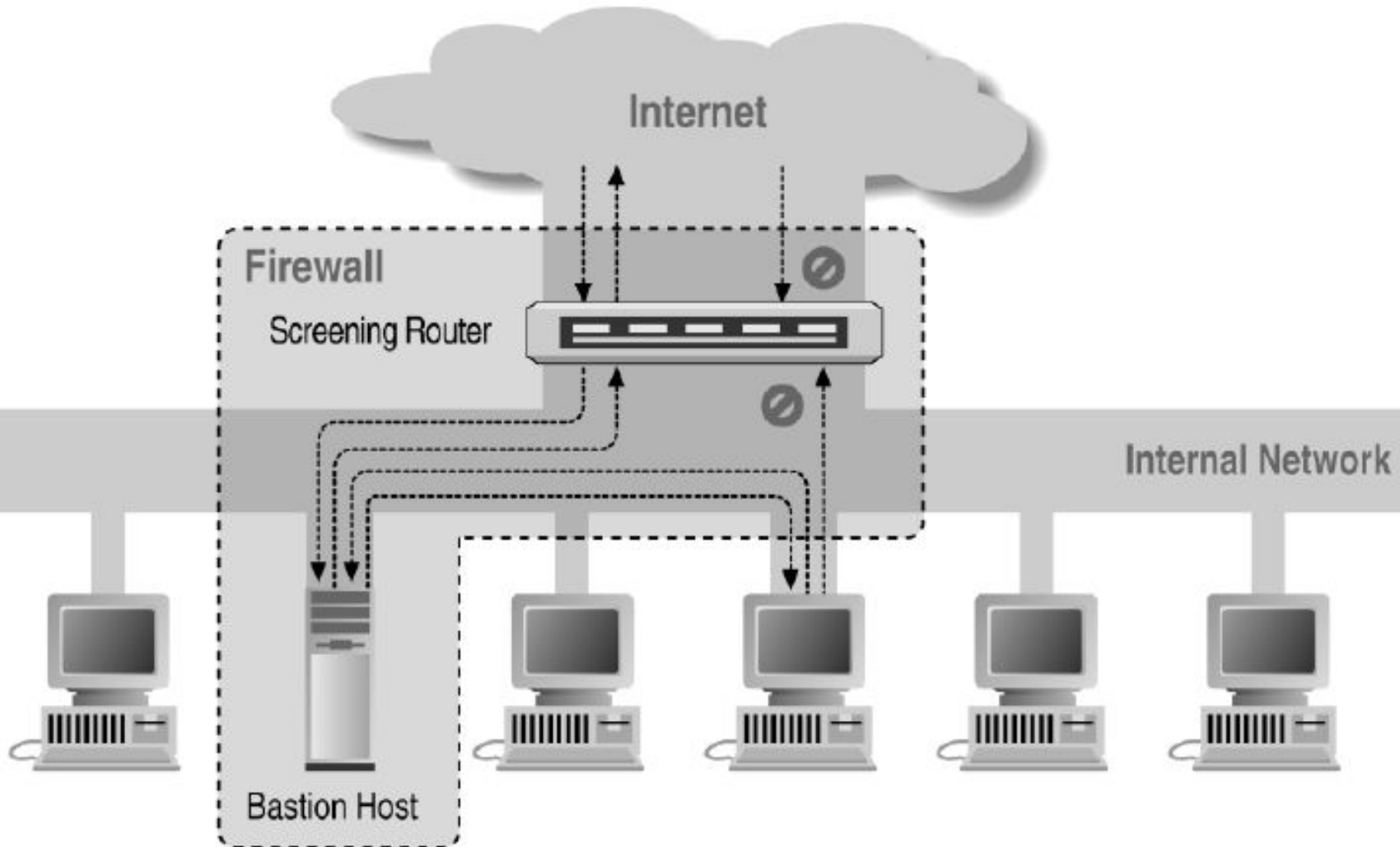
- In this question, we explore some applications and limitations of a packet filtering firewall. For each of the question, briefly explain 1) can stateless firewall be configured to defend against the attack and how?
2) if not, what about stateful firewall ?
3) if neither can, what about application-level proxy?
- Can the firewall prevent a SYN flood attack from the external network?
- Can the firewall prevent a Smurf attack from the external network?
Basically, the Smurf attack uses the broadcast IP address of the subnet.
- Can the firewall prevent XSS attacks?

Where to Deploy App-level Firewall

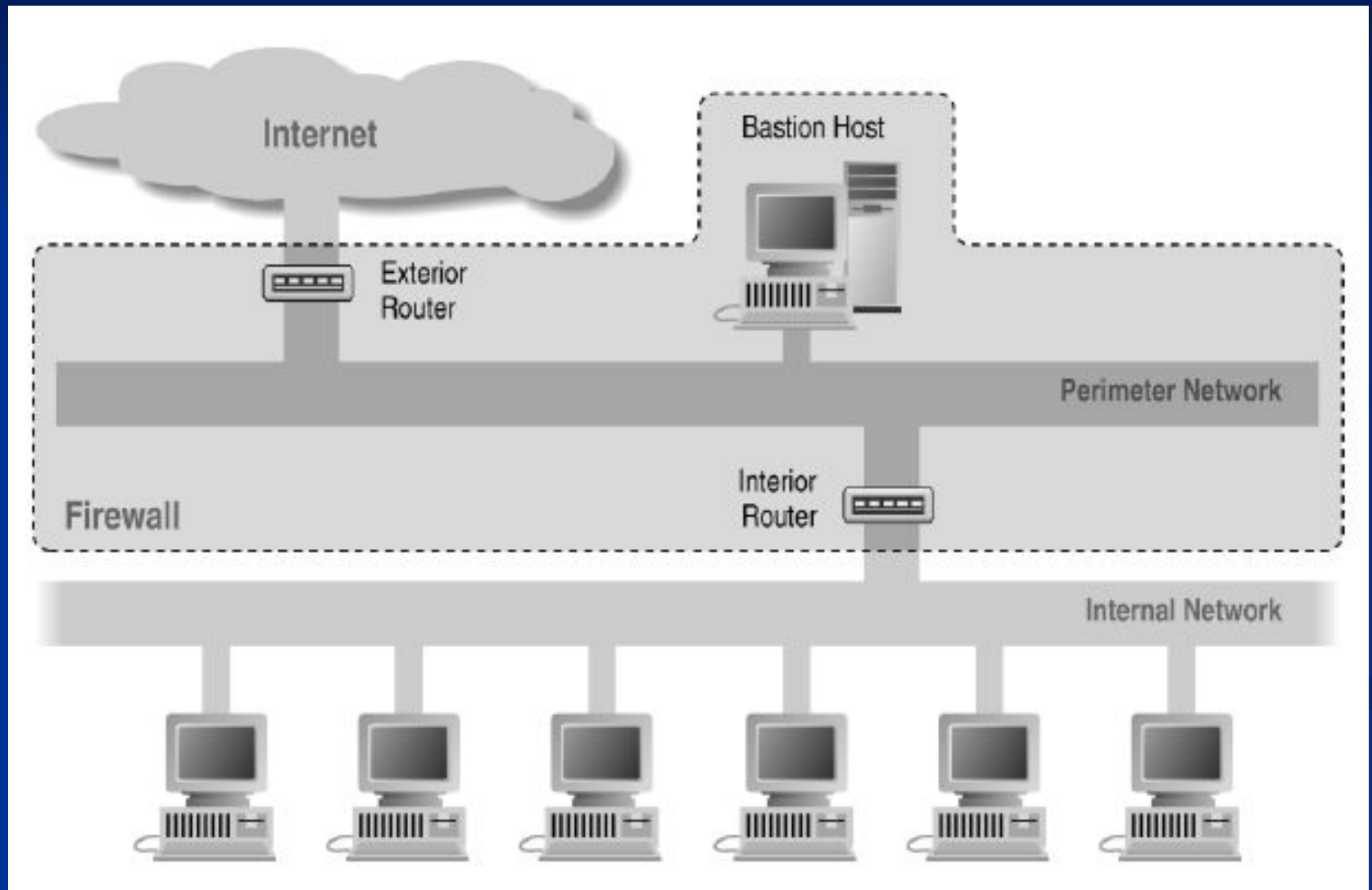
Bastion Host: highly secure host system

- Potentially exposed to "hostile" elements
- Hence is secured to withstand this
 - Disable all non-required services; keep it simple
- Runs circuit / application level gateways
 - Install/modify services you want
- Or provides externally accessible services

Screened Host Architecture



Screened Subnet Using Two Routers



Backup Slides

Solution 2:

action	ourhost	port	theirhost	port	comment
allow	*	*	*	25	<i>connection to their SMTP port</i>

This solution allows calls to come from any port on an inside machine, and will direct them to port 25 on the outside. Simple enough...

So why is it wrong?

- Our defined restriction is based solely on the outside host's port number, which we have no way of controlling.
- Now an enemy can access any internal machines and port by originating his call from port 25 on the outside machine.

What can be a better solution ?

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	25		<i>our packets to their SMTP port</i>
allow	*	25	*	*	ACK	<i>their replies</i>

- The ACK signifies that the packet is part of an ongoing conversation
- Packets without the ACK are connection establishment messages, which we are only permitting from internal hosts

Network Topology

Filter Rule: Open access to Net 2 means source address from Net 3

- Why not spoof address from Net 3?

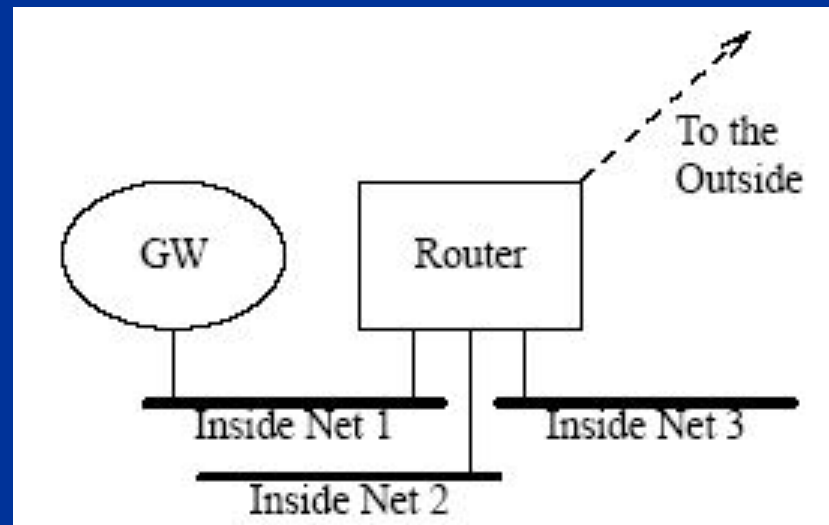


Figure 9.2: A firewall router with multiple internal networks.

Address-Spoofing

- Detection is virtually impossible unless source-address filtering and logging are done
- One should not trust hosts outside of one's administrative control

External Interface Ruleset

Allow outgoing calls, permit incoming calls only for mail and only to gateway GW

action	src	port	dest	port	flags	comment
block	{NET 1}	*	*	*		<i>block forgeries</i>
block	{NET 2}	*	*	*		
block	{NET 3}	*	*	*		
allow	*	*	GW	25		<i>legal calls to us</i>
allow	*	*	{NET 2}	*	ACK	<i>replies to our calls</i>
allow	*	*	{NET 3}	*	ACK	

Note: Specify GW as destination host instead of Net 1 to prevent open access to Net 1

Net 1 Router Interface Ruleset

- Gateway machine speaks directly only to other machines running trusted mail server software
- Relay machines used to call out to GW to pick up waiting mail

action	src	port	dest	port	flags	comment
allow	GW	*	{partners}	25		<i>mail relay</i>
allow	GW	*	{NET 2}	*	ACK	<i>replies to inside calls</i>
allow	GW	*	{NET 3}	*	ACK	
block	GW	*	{NET 2}	*		<i>stop other calls from GW</i>
block	GW	*	{NET 3}	*		
allow	GW	*	*	*		<i>let GW call the world</i>

Note: Spoofing is avoided with the specification of GW

Dual Homed Host Architecture

